

Race Condition

Bối cảnh (Context)

Sàn giao dịch tiền ảo "CryptoFast" cho phép người dùng đổi mã Voucher để nhận 1 đồng xu nền tảng. Mã Voucher chỉ được sử dụng một lần duy nhất. Hệ thống chạy rất nhanh và có vẻ như họ đã viết hàm kiểm tra Voucher hợp lệ trước, rồi mới tiến hành xóa Voucher đó khỏi cơ sở dữ liệu ở dòng code tiếp theo.

Một nhóm hacker nhận ra rằng, điều gì sẽ xảy ra nếu họ gửi yêu cầu đổi Voucher nhanh đến mức máy chủ chưa kịp hoàn tất việc xóa Voucher?

Mục tiêu (Objective)

- **Nhiệm vụ:** Từ một mã Voucher chỉ đổi được 1 xu, hãy đổi làm sao để nhận được ít nhất 10 xu.
- **Vấn đề / Lỗi hỏng: Race Condition (Lỗi tương tranh)** - cụ thể là TOCTOU (Time of Check to Time of Use). Khi nhiều luồng (threads) cùng lúc thực hiện thao tác kiểm tra mã Voucher, tất cả đều thấy Voucher chưa bị xóa và đều tiến hành cấp tiền, dẫn đến việc nhận tiền nhiều lần trước khi các luồng kịp xóa Voucher.
- **Flag:** Flag sẽ tự động hiện ra khi số dư xu của bạn vượt qua mốc yêu cầu.

Gợi ý (Hints)

- Bạn không thể khai thác lỗi này bằng cách bấm chuột. Bạn cần gửi hàng chục/hàng trăm request đổi tiền **cùng một thời điểm chính xác**.
- Dùng tính năng Turbo Intruder trong Burp Suite, hoặc viết một script Python sử dụng Threading/Asyncio để gửi lệnh đồng thời.